



**TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI**
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

CHƯƠNG 6

BẢO MẬT TĂNG MẠNG

ONE LOVE. ONE FUTURE.



TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

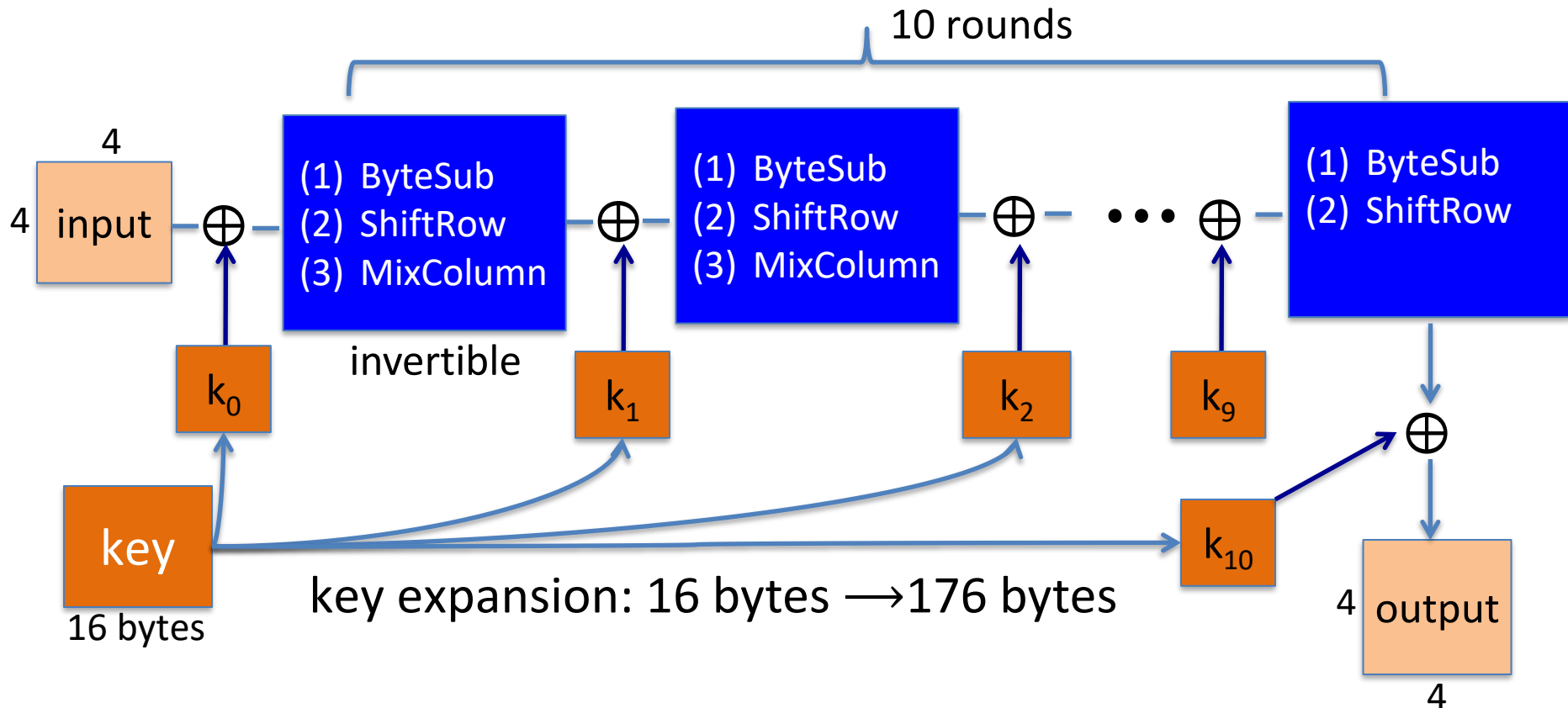
AES

Advanced Encryption Standard (AES)

ONE LOVE. ONE FUTURE.

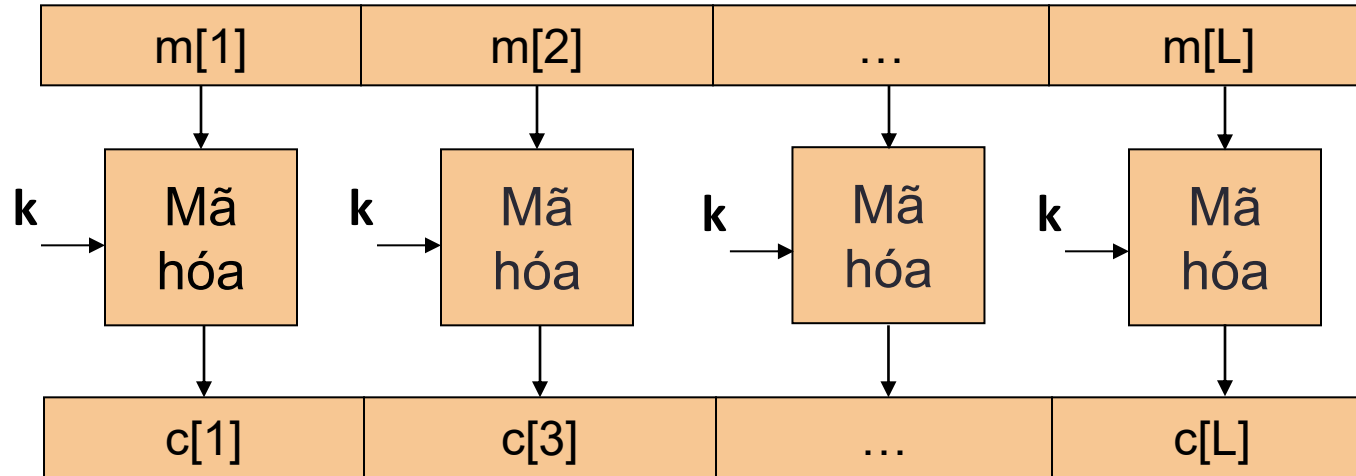
Mật mã AES

- Kích thước khóa: 128, 192, 256 bit
- Kích thước khối: 128 bit
- Số vòng lặp: 10, 12, 14 theo kích thước khóa

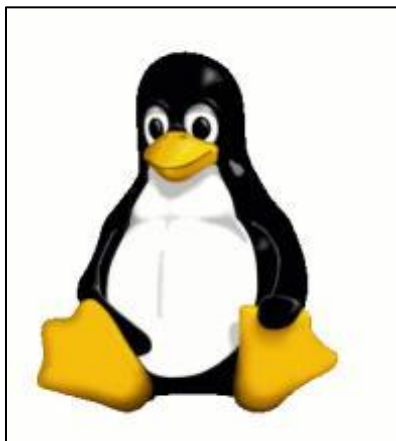


Các chế độ mã khối

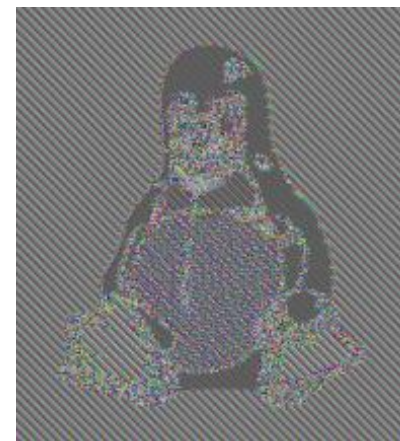
- Electronic Code Book (ECB): Mã từ điển



- Hạn chế: ECB không chống lại được tấn công KPA

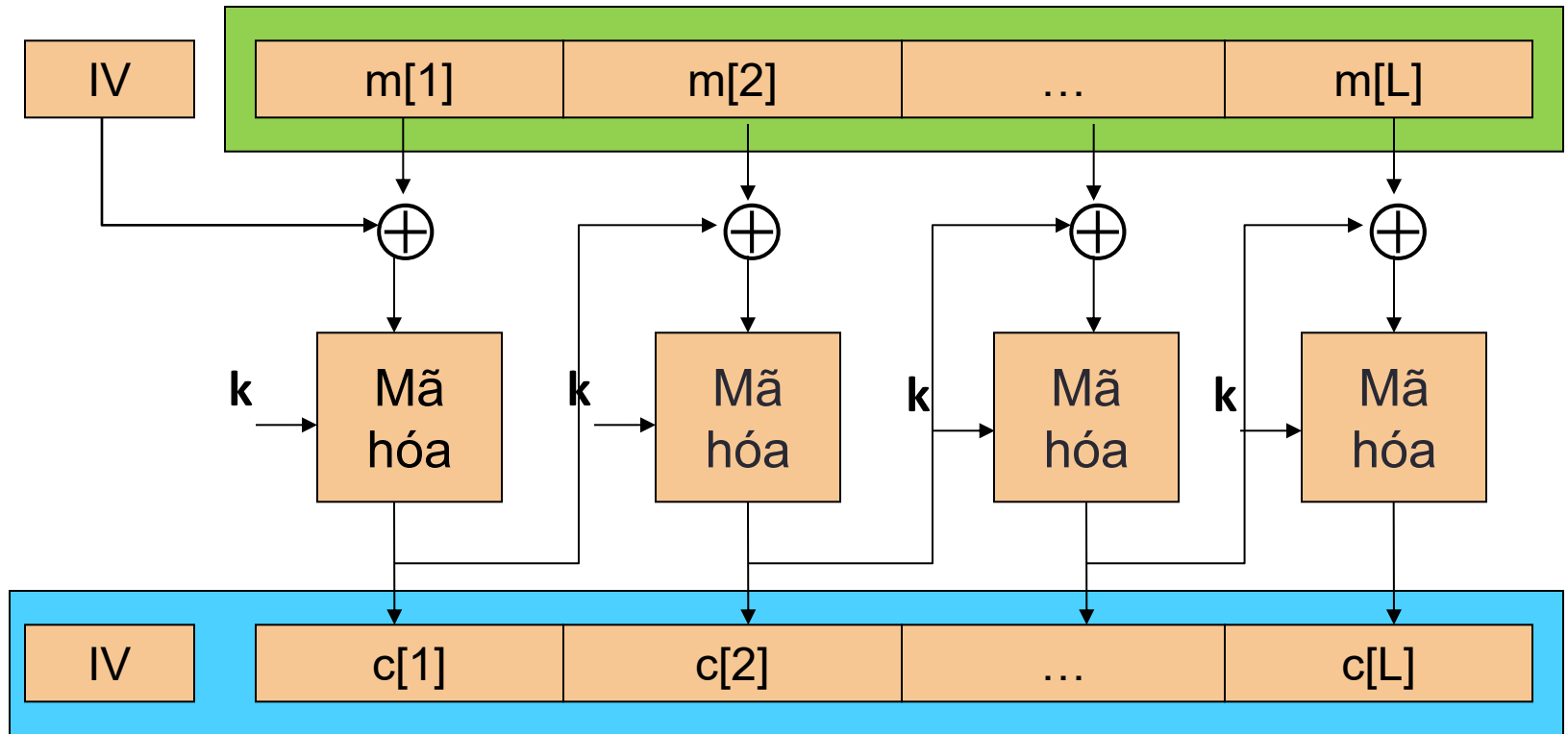


ECB →



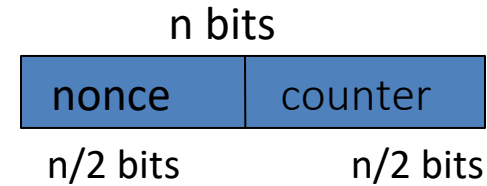
Chế độ CBC - Cipher Block Chaining

- Chế độ móc xích

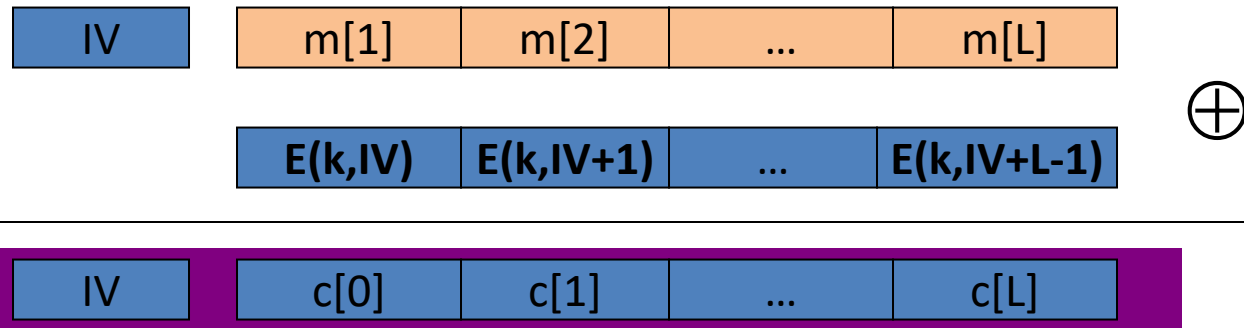


Chế độ CTR – Counter Mode

- Initial Vector:
 - nonce: giá trị ngẫu nhiên
 - counter: khởi tạo bằng 0

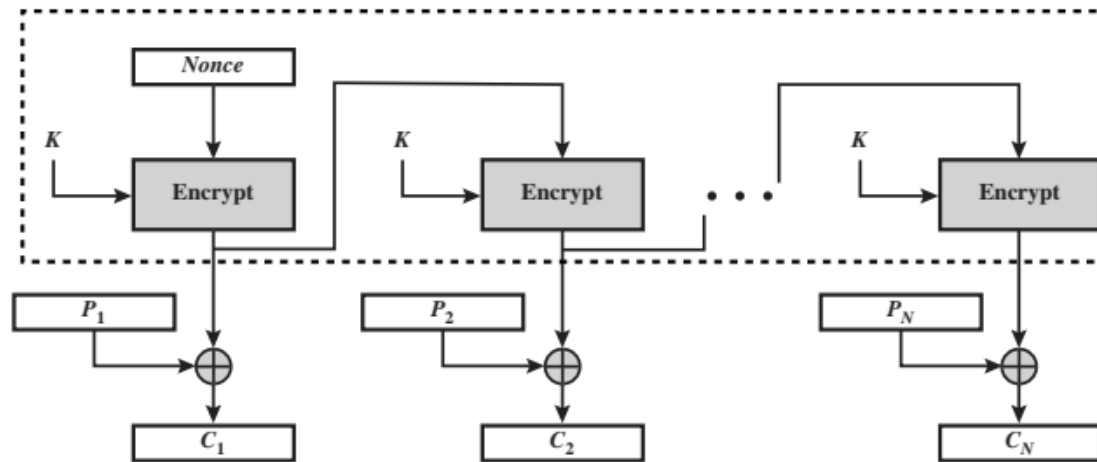


- Mã hóa: không cần padding

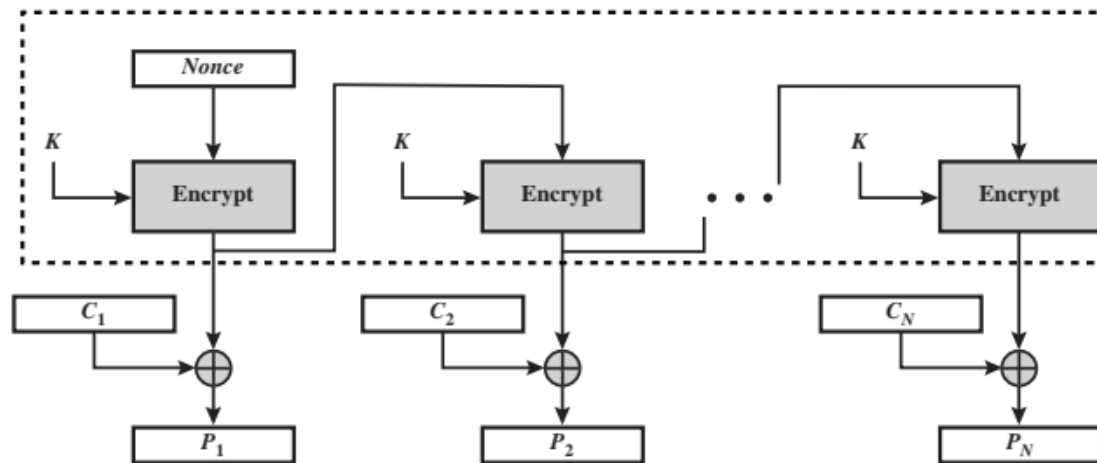


- Nếu IV lặp lại, chế độ CTR không an toàn

Output Feedback - OFB



(a) Encryption



(b) Decryption



TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

Hệ mật RSA

Khóa mã hóa $\neq$ Khóa giải mã

ONE LOVE. ONE FUTURE.

- Sinh khóa:
 - Chọn p, q là hai số nguyên tố ngẫu nhiên
 - Tính $n = p \times q$, $\Phi(n) = (p-1) \times (q-1)$
 - Chọn e sao cho $\text{UCLN}(\Phi(n), e) = 1$; $1 < e < \Phi(n)$
 - Tính d sao cho $(e \times d) \bmod \Phi(n) = 1$; $1 < d < \Phi(n)$
 - Khóa công khai : $k_U = (e, n)$
 - Khóa riêng : $k_R = (d, n)$
- Mã hóa : $c = m^e \bmod n$ (điều kiện: $m < n$)
- Giải mã: $m = c^d \bmod n$ (điều kiện: $c < n$)

- Cho $p=5$, $q=11$, $e=13$. Tính khóa riêng (d,n) trong phương pháp RSA
- Thực hiện mã hóa và giải mã bằng phương pháp RSA với $p=17$, $q=19$, $e=13$, $m=13$
- Giả sử khóa công khai của Alice là $(7,221)$. Thực hiện phá mã RSA và tính thông điệp bản rõ nếu biết bản mã $c=3$.



TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

ECC

Elliptic Curve Cryptography

ONE LOVE. ONE FUTURE.

Phương trình đường cong Elliptic

- Phương trình đường cong Elliptic

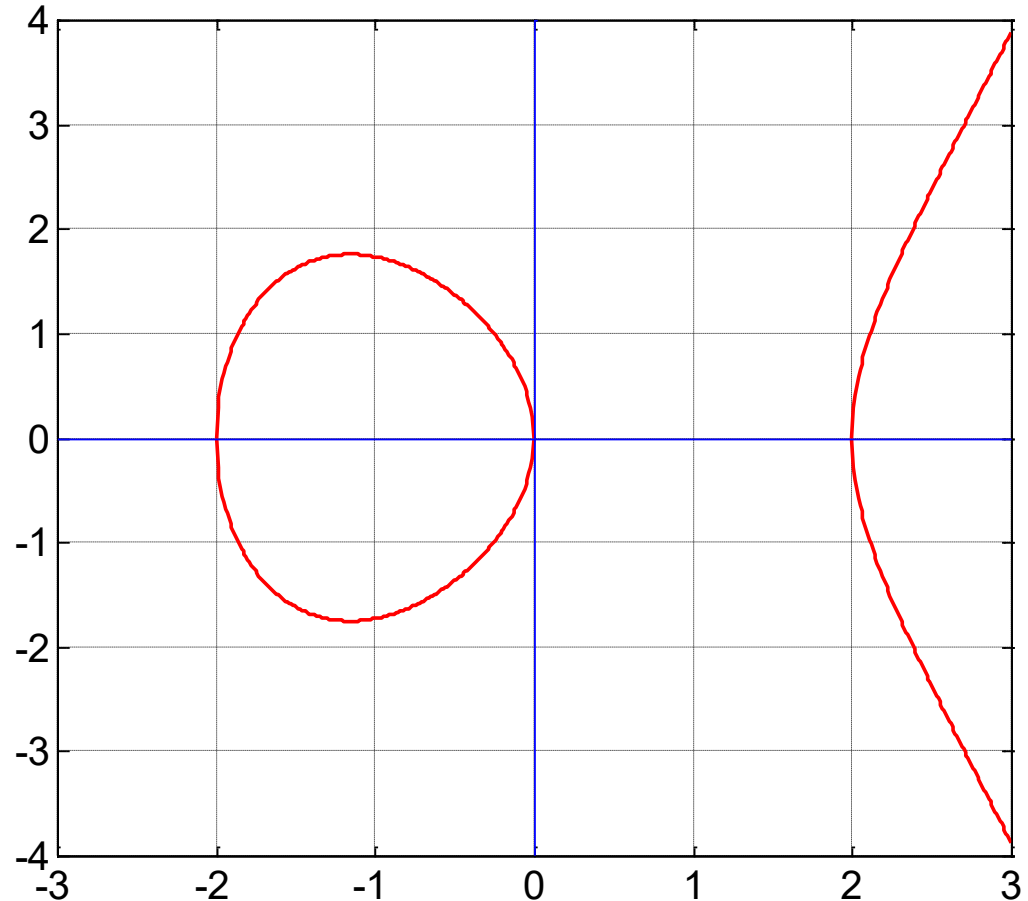
$$y^2 = x^3 + ax + b$$

- Thỏa mãn điều kiện:

$$4a^3 + 27b^2 \neq 0$$

Ví dụ:

$$\begin{aligned} y^2 &= x^3 - 4x \\ &= x(x-2)(x+2) \end{aligned}$$



Phép cộng trên đường cong Elliptic

g: $y = s \cdot x + y_0$

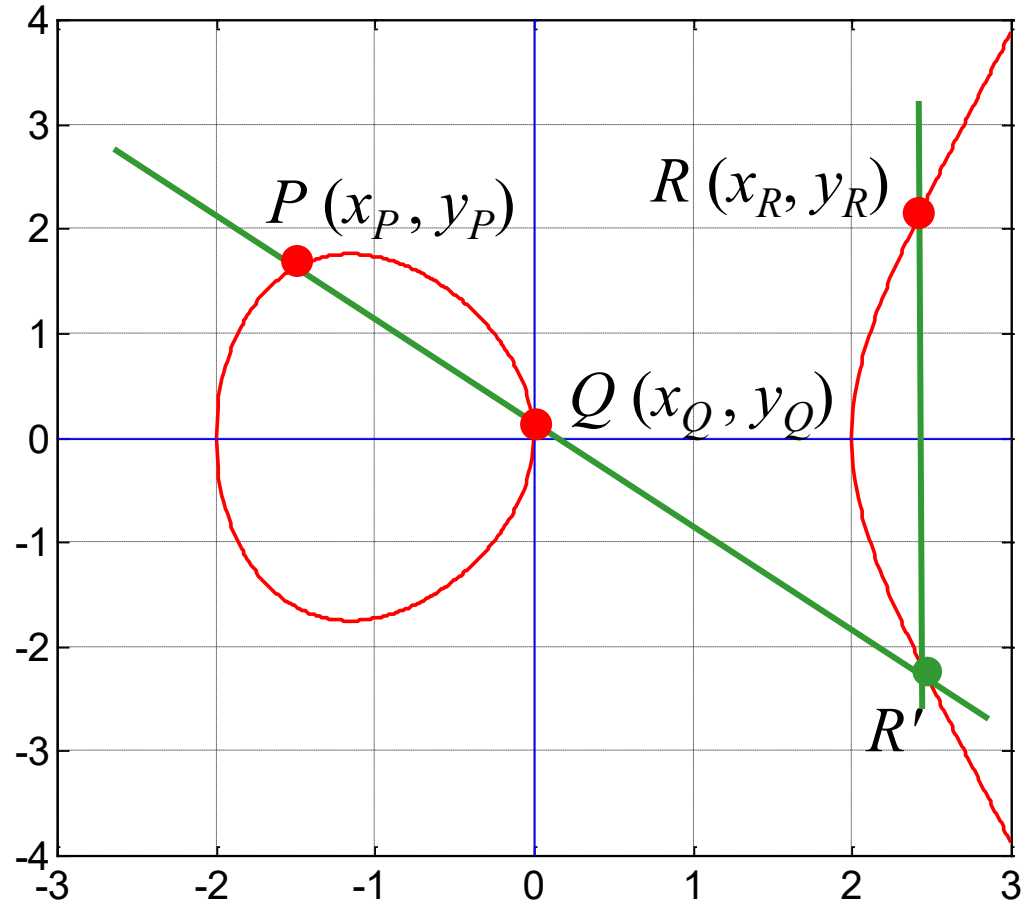
với
$$s = \frac{y_Q - y_P}{x_Q - x_P}$$

$$y_0 = y_P - s \cdot x_P$$

Tọa độ của điểm R:

$$x_R = s^2 - x_P - x_Q$$

$$y_R = -(s \cdot x_R + y_0)$$



Phép nhân đôi trên đường cong Elliptic

g: $y = s \cdot x + y_0$

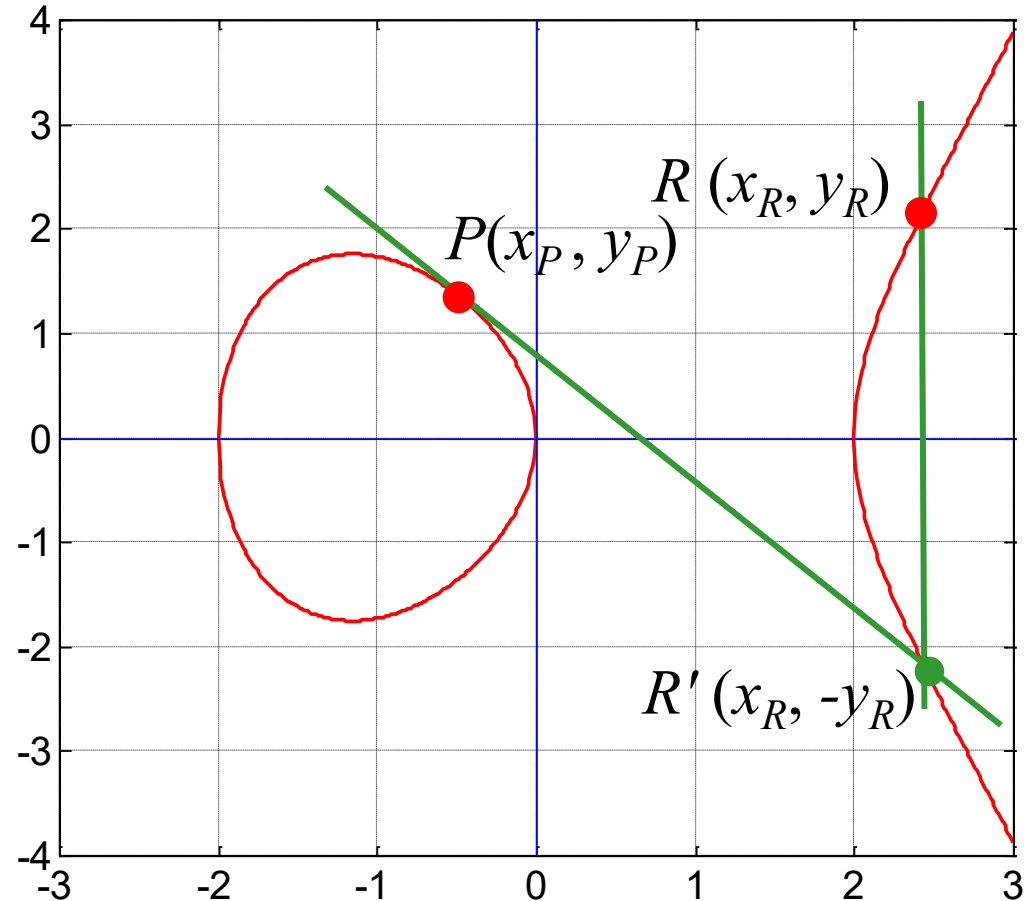
$$s = \frac{dy}{dx} = \frac{3x_P^2 + a}{2y_P}$$

$$y_0 = y_P - s \cdot x_P$$

Tọa độ của điểm R:

$$x_R = s^2 - 2x_P$$

$$y_R = -(s \cdot x_R + y_0)$$



Đường cong Elliptic trên trường Galois

- Đường cong Elliptic trên trường Galois $GF_p \pmod p$ (p là số nguyên tố) nhận được bằng phép tính:

$$y^2 = x^3 + ax + b \pmod p$$

- Cho đường cong Elliptic $y^2 = x^3 + ax + b \pmod p$, chọn một điểm sinh P và thực hiện phép nhân với một phần tử k , $Q=kP$. Q là khóa công khai và k là khóa cá nhân trong hệ mật khóa bất đối xứng.

- Cho điểm sinh $P(2,4)$ nằm trên đường cong Elliptic $y^2 = x^3 + x + 6 \pmod{11}$. Tìm giá trị của $2P$ và $3P$.

Thông tin tham khảo – Kích thước khóa

Date	Minimum of Strength	Symmetric Algorithms	Factoring Modulus	Discrete Logarithm Key	Discrete Logarithm Group	Elliptic Curve	Hash (A)	Hash (B)
2010 (Legacy)	80	2TDEA*	1024	160	1024	160	SHA-1** SHA-224 SHA-256 SHA-384 SHA-512	SHA-1 SHA-224 SHA-256 SHA-384 SHA-512
2011 - 2030	112	3TDEA	2048	224	2048	224	SHA-224 SHA-256 SHA-384 SHA-512	SHA-1 SHA-224 SHA-256 SHA-384 SHA-512
> 2030	128	AES-128	3072	256	3072	256	SHA-256 SHA-384 SHA-512	SHA-1 SHA-224 SHA-256 SHA-384 SHA-512
>> 2030	192	AES-192	7680	384	7680	384	SHA-384 SHA-512	SHA-224 SHA-256 SHA-384 SHA-512
>>> 2030	256	AES-256	15360	512	15360	512	SHA-512	SHA-256 SHA-384 SHA-512



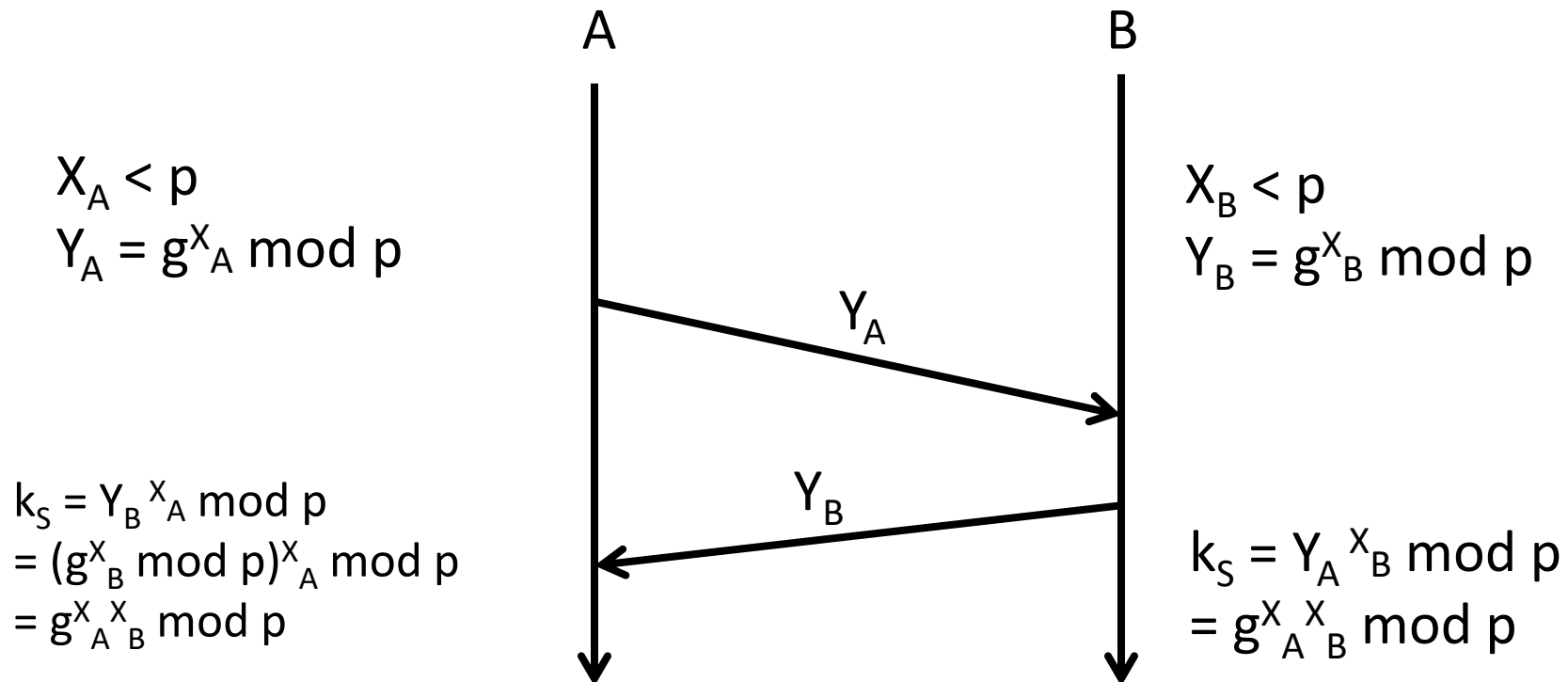
**TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI**
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

Giao thức mật mã

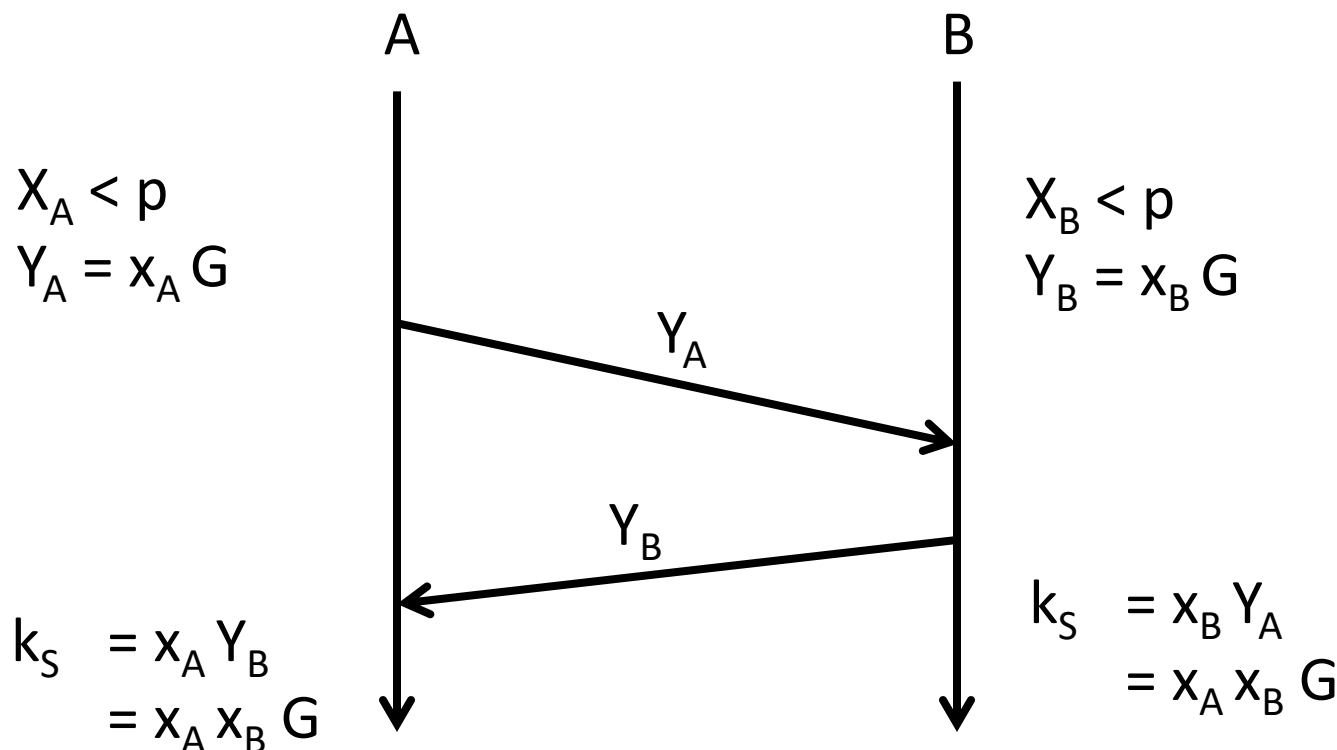
ONE LOVE. ONE FUTURE.

Sơ đồ trao đổi khóa Diffie-Hellman

- Alice và Bob cùng chia sẻ một khóa nhóm (p, g) .
Trong đó
 - p là một số nguyên tố
 - $1 < g < p$ thỏa mãn: $(g^i \bmod p) \neq (g^j \bmod p) \forall 1 \leq i \neq j < p$



- Alice và Bob cùng chia sẻ một điểm sinh G .



Tổng quan

Giao thức	Tiêu chuẩn	Thuật toán mã hóa	Năng lượng tiêu thụ
6LoWPAN	IEEE 802.15.4	AES	Thấp
NFC	ISO/IEC 14443	RSA/DSA	Thấp
Bluetooth	IEEE 802.16	AES, ECDH	Trung bình/Rất thấp (BLE)
Wi-Fi	IEEE 802.11i/e/g	AES	Cao
ZigBee	IEEE 802.15.4	AES	Thấp
WiMAX	IEEE 802.16	RSA	Trung bình
3G/4G/5G	UMTS/LTE	RSA, 3DES	Trung bình
RPL	IETF RPL	AES	Thấp



TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

NFC

Near-Field Communication

ONE LOVE. ONE FUTURE.

Tổng quan về NFC

- Barcodes (1940s)
 - RFID (1960s – 1970s): RFID Tag + RFID Reader
- Magnetic Stripe Cards (1960s)
 - Thẻ thông minh (1970s): Thẻ thông minh tiếp xúc & không tiếp xúc
- Mobile Phones (1940s)
 - NFC Enabled Mobile Phone
- Near Field Communication (2002)

Tổng quan về NFC

- Công nghệ kết nối không dây khoảng cách gần
 - Tần số: 13.56 MHz
 - Dựa trên công nghệ RFID
 - Tốc độ truyền dữ liệu : 106 - 424 kbps
- Ưu điểm:
 - Thời gian thiết lập: < 0.1 ms
 - Khoảng cách: 0 – 10 cm
 - Tương thích ngược
 - Trải nghiệm người dùng
 - Kết nối bảo mật
 - Cấu hình và thiết lập tự động

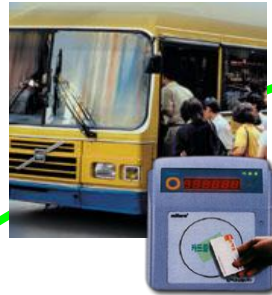
Tổng quan về NFC

	WiFi	Bluetooth	Infrared	NFC
Range	0 - 100 m	0 -10 m	0 – 1 m	0 – 10 cm
Transfer rate	High (54 Mbps)	Medium (1 Mbps)	Medium (4 Mbps)	Low (424 kbps)
Security	Low	High	Low	Very High
Cost	High	Medium	Medium	Very Low

	RFID	Bluetooth	Zigbee	NFC
Security	High	Low	Low	High
Personalization	High	Medium	Low	High
Flexibility	Low	High	High	High
Power Consumption	Low	High	Medium	Low

- ISO/IEC 18092 / ECMA-340 – Near Field Communication interface and Protocol-1 (NFCIP)
- ISO/IEC 21481 / ECMA-352 – Near Field Communication interface and Protocol-2 (NFCIP-2)
- NFC Forum - NFC Data Exchange Format (NDEF)

Thanh toán điện tử
Hệ thống thanh toán không tiếp xúc



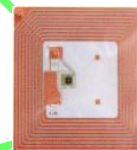
Trao đổi dữ liệu
Kết nối không dây tốc độ thấp



NFC

NFC

Xác thực định danh
Tài liệu định danh điện tử



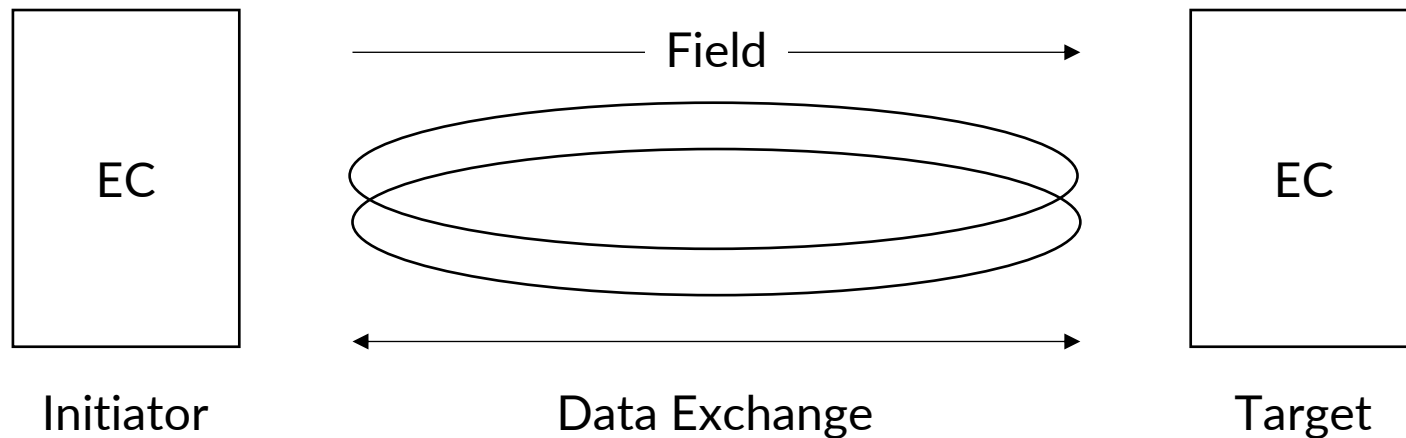
NFC

Câu hỏi thảo luận

- Giải thích sự khác nhau giữa mã QR và công nghệ RFID
- Giải thích sự khác nhau giữa RFID Tag chủ động và bị động
- Giải thích sự khác nhau giữa RFID Tag và thẻ thông minh không tiếp xúc

Chế độ hoạt động

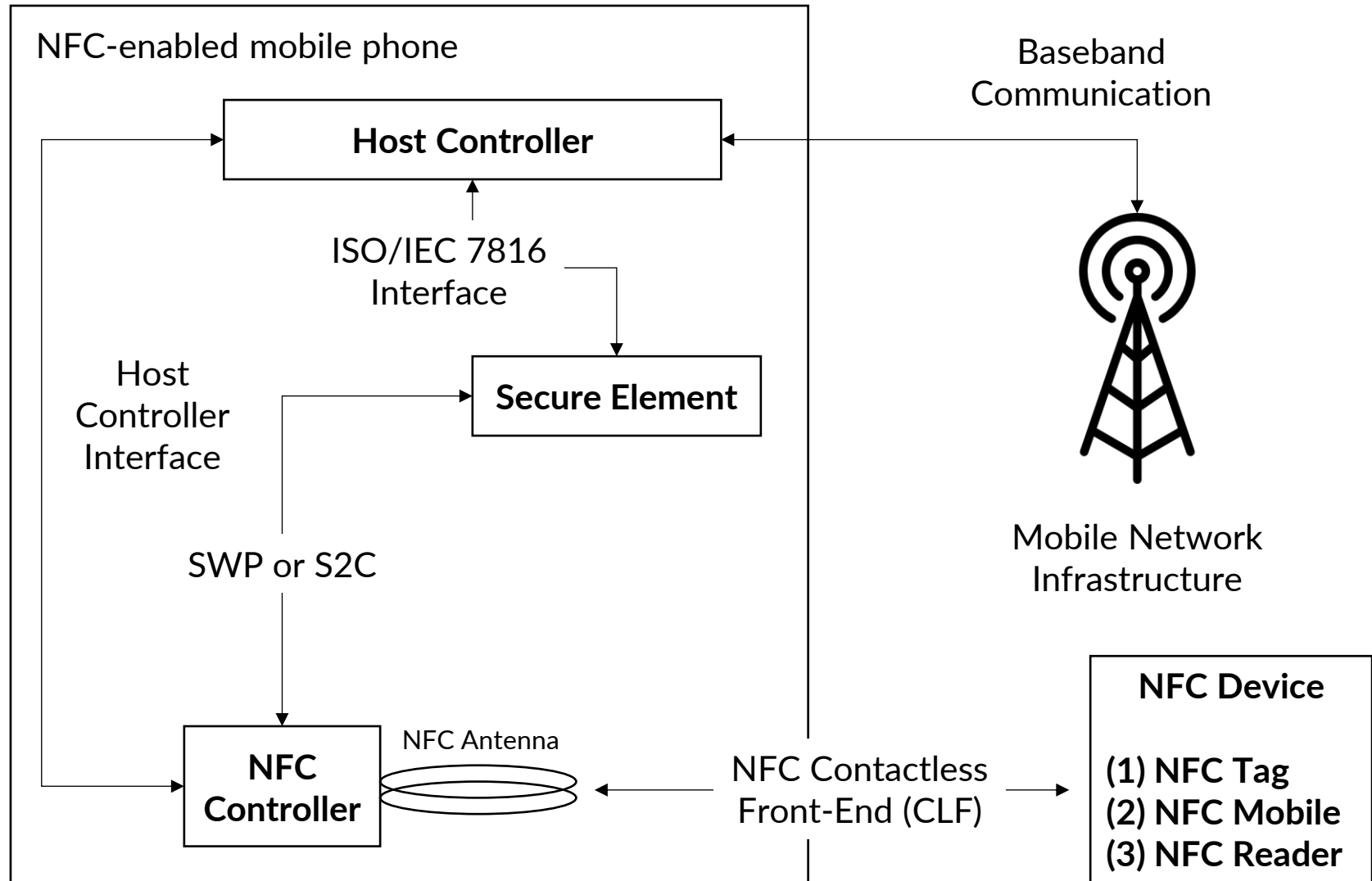
- Thiết bị NFC hoạt động với một hoặc một vài chế độ và được phân biệt bởi khả năng tự phát sóng (**chủ động**) hoặc nhận năng lượng hoạt động từ sóng của thiết bị khác (**bị động**).
- Thiết bị NFC có thể đóng vai trò khởi tạo kết nối (initiator) hoặc phản hồi yêu cầu (target)



Thiết bị NFC

- Điện thoại di động hỗ trợ NFC (**NFC-enabled mobile phone**): Điện thoại di động hoạt động như một thẻ thông minh bảo mật, hỗ trợ các ứng dụng như thanh toán điện tử, kiểm soát truy cập
- **NFC tag**: Dạng thiết bị RFID bị động với khả năng trao đổi dữ liệu hai chiều với một thiết bị NFC khác.
- Thiết bị đầu đọc NFC (**NFC Reader**): Thiết bị chủ động với khả năng trao đổi dữ liệu hai chiều cùng một thiết bị NFC khác. Thiết bị đầu đọc NFC có thể tích hợp trên điện thoại di động hoặc các điểm bán hàng không tiếp xúc (Contactless POS)

Kiến trúc hệ thống di động hỗ trợ NFC



Nền tảng bảo mật NFC

- Bảo mật NFC Tag
- Bảo mật NFC Reader
- Bảo mật thẻ thông minh
- Bảo mật phiên truyền thông
- Bảo mật hệ thống Middleware và Backend
- Giao thức bảo mật

- C. Mulliner, *Vulnerability Analysis and Attacks on NFC-enabled Mobile Phones*, International Conference on Availability, Reliability and Security, Fukuoka, Japan, 2009
- Tìm hiểu về bảo mật của NFC Tag & Reader

Bảo mật NFC Tag & Reader

- Các kỹ thuật tấn công NFC Tag
 - Nhân bản và giả mạo NFC Tag
 - Thay đổi nội dung Tag
 - Thay thế Tag bằng một Tag khác được tạo ra bởi tin tặc
- Các kỹ thuật tấn công NFC Reader
 - Bóc tác và phá hủy NFC Reader
 - Giả mạo NFC Reader

Bảo mật thể thông minh

- Tấn công xâm lấn
- Tấn công không xâm lấn
- Tấn công vật lý
- Tấn công logic
- Tấn công Trojan Horse
- Kỹ nghệ xã hội

Bảo mật thẻ thông minh

- Nghe lén
- Thay đổi thông tin hoặc chèn dữ liệu độc hại
- Tấn công người đứng giữa
- Tấn công phát lại

Phân tích vi sai thời gian (Kocher et al. 1997)

- Bản chất tấn công vào mật mã RSA.
- Khóa cá nhân: (d, N)
- Giả thiết khóa cá nhân $d = d_n d_{n-1} \dots d_0 = \sum_{i=0}^n 2^i d_i$
- Ký số:

$$C = M^d = M^{\sum_{i=0}^n 2^i d_i} \bmod N$$

- Tích hợp:

$$z = M; C = 1$$

for $i = 0$ to n do

if $(d_i = 1)$ then $C = C * z \bmod N$

$$z = z^2 \bmod N$$

Các giao thức bảo mật NFC

- NFC-SEC: NFCIP-1 Security Services and Protocol – ECMA 385:
 - Cung cấp các tiêu chuẩn an toàn cho kết nối NFC, cân bằng giữa hai yếu tố bảo mật và hiệu năng
 - Bao gồm các hàm mã hóa tại tầng liên kết dữ liệu
 - ECMA-385 là tập hợp các phương thức cơ bản, ngăn chặn tấn công nghe lén hoặc thay đổi dữ liệu.
 - ECMA-386 NFC-SEC-01 quy định cơ chế mật mã dựa trên ECDH cho phân thỏa hiệp khóa và thuật toán mã hóa AES.

NFC-SEC và kiến trúc của NFC-SEC

- Kiến trúc NFC-SEC sử dụng mô hình OSI và được định nghĩa trong chuẩn ISO/IEC 7498-1, 7498-2.
 - Người dùng truy cập dịch vụ NFC-SEC thông qua NFC-SEC Service Access Point (NFC-SEC-SAP).
 - Các thực thể NFC-SEC tiếp nhận và phản hồi yêu cầu từ người dùng và để cung cấp dịch vụ NFC-SEC, chúng thực hiện trao đổi NFC-SEC-PDU (Protocol Data Unit).
- Luồng hoạt động của dịch vụ NFC-SEC:
 - Key Agreement: ACT_REQ & ACT_RES
 - Key Confirmation: VFY_REQ & VFY_RES
 - PDU Security: ENC
 - Termination: TMN

Cơ chế NFC-SEC-01 sử dụng ECDH và AES

- NFC-SEC-01 định nghĩa cách thức bảo mật phiên truyền thông của các thực thể NFC mà giữa chúng không tồn tại khóa bí mật chia sẻ trước.
- Các cơ chế nguyên thủy của NFC-SEC-01 (Chi tiết tham khảo tiêu chuẩn ECMA 386):
 - Elliptic Curve Diffie-Hellman (ECDH) Key exchange: 192-bit
 - Key derivation and confirmation: AES 128-bit
 - Data encryption: AES 128-bit
 - Data integrity: AES 128-bit
- NFC-SEC-01 có thể bị tấn công MITM (Nguy cơ **thấp** do yêu cầu khoảng cách gần giữa các thực thể kết nối)



**TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI**
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

Bluetooth

ONE LOVE. ONE FUTURE.

Quá trình hình thành và phát triển

- 1994: Dự án của Ericsson với tên gọi Bluetooth
- 1998: Dự án Bluetooth SIG và Công nghệ Bluetooth
- 1999: Bluetooth 1.0 và Bluetooth 1.0B
- 2000: Sản phẩm thương mại đầu tiên sử dụng Bluetooth
- 2003: Bluetooth 1.2
- 2004: Bluetooth 2.0
- 2006: Liên minh Wimedia
- 2007-2021: Bluetooth 2.1, 3.0, 4.0-4.2, 5.0-5.3

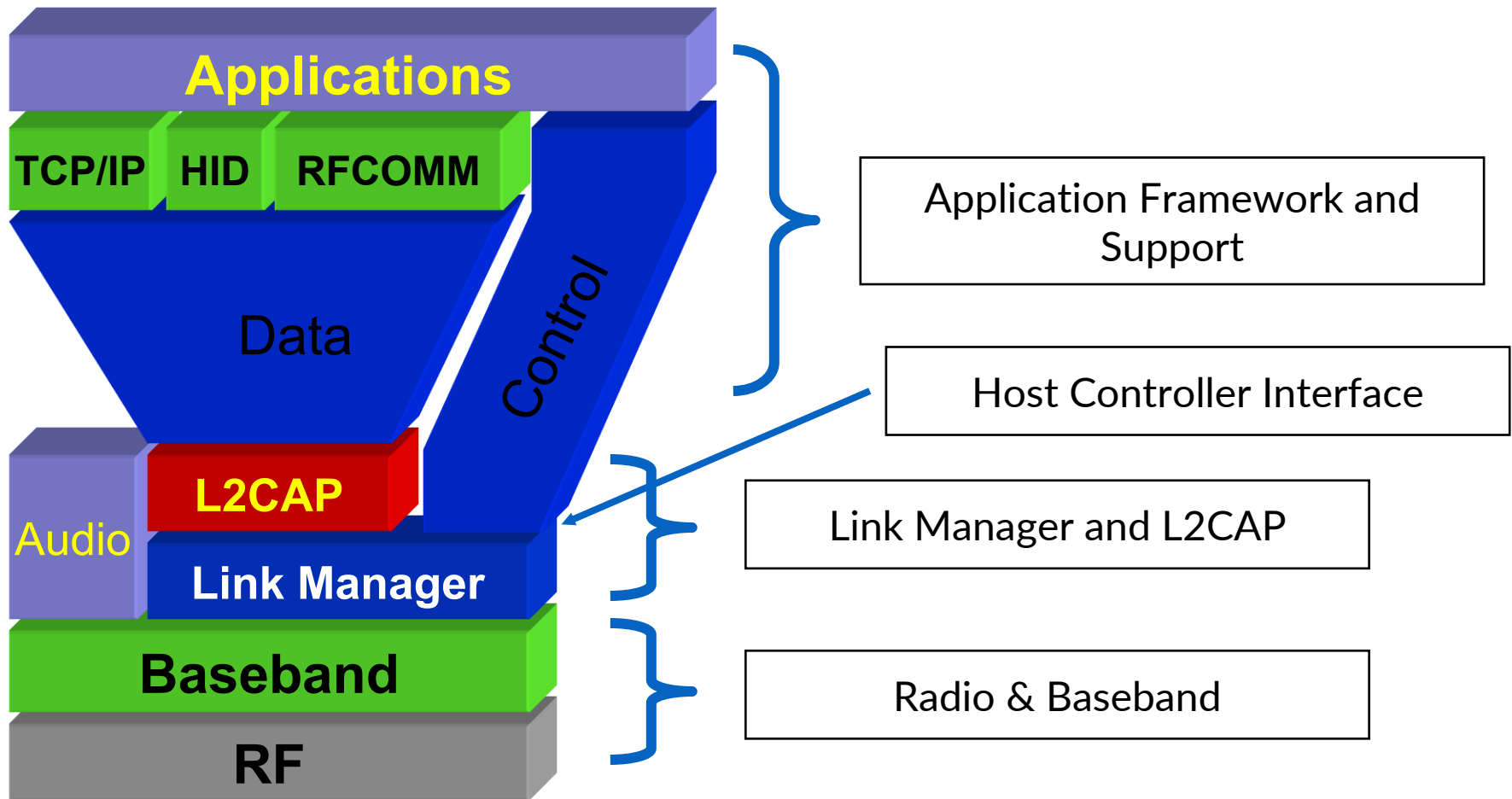
Tổng quan về Bluetooth

- Công nghệ kết nối không dây
 - Tần số: 2.40 – 2.48 GHz
 - Tốc độ truyền dữ liệu:
 - Bluetooth 2.1: 1-3 Mbps
 - Bluetooth 4.0 (LE): 1 Mbps
 - Khoảng cách: Lên đến 10 m
 - Phương pháp điều chế: Gaussian FSK
 - Hỗ trợ lên đến 8 thiết bị trong mạng Piconet

Ứng dụng của Bluetooth

- Thiết bị thông minh
- Thiết bị truyền thanh
- Thiết bị truyền dữ liệu
- Các ứng dụng nhúng
- Các ứng dụng khác

Các tầng giao thức Bluetooth



Bluetooth radio

- Định nghĩa những yêu cầu cho bộ phận thu phát sóng hoạt động ở tần số 2.4GHz. Sóng Bluetooth có thể đâm xuyên được qua các vật thể rắn và phi kim
- Sóng Bluetooth được thiết kế tiêu thụ ít năng lượng. Thiết bị có thể tối ưu mức năng lượng bằng cách dùng các lệnh LMP

Bluetooth baseband

- Giao thức nằm ở tầng vật lý của Bluetooth
- Liên kết đồng bộ và bất đồng bộ, địa chỉ thiết bị, định dạng gói tin, quản lý trạng thái, thiết lập kết nối, các chế độ kết nối và những chức năng khác của Baseband

Hình trạng của mạng Bluetooth

- Piconet

- 01 Master và nhiều (≤ 07) Slave
- Giữa các Slave trong một Piconet không trao đổi trực tiếp với nhau
- Vai trò Master trong một Piconet không cố định

- Scatternet

- Hai hay nhiều Piconet kết hợp tạo thành một Scatternet
- Giữa hai thiết bị luôn tồn tại tối thiểu một đường kết nối
- Thiết bị chỉ có thể đóng vai trò Master trong một Piconet
- Thiết bị Slave có thể Slave hoặc Master trong một Piconet khác
- Dữ liệu được chuyển tiếp qua thiết bị trung gian là thành viên của hai mạng Piconet. Giao thức Bluetooth không định nghĩa thủ tục chuyển tiếp mà việc đó do phần mềm ứng dụng thực hiện

- Synchronous Connection Oriented (SCO)
 - Liên kết Point-to-Point giữa Master và Slave trong một Piconet
 - SCO chủ yếu được dùng để truyền âm thanh, hình ảnh
 - Master có thể hỗ trợ tối đa 3 kết nối SCO đồng thời
 - Gói tin SCO không có CRC và không bao giờ truyền lại
- Asynchronous Connectionless Link (ACL)
 - Liên kết Point-to-Multipoint giữa Master và tất cả Slave trong Piconet
 - Kết nối ACL được dùng để truyền dữ liệu
 - Hầu hết gói ACL đều có thể truyền lại

Địa chỉ thiết bị

- Có 04 loại địa chỉ khác nhau có thể gán cho một thiết bị:
 - **BD_ADDR (Bluetooth Device Address):** 48-bit địa chỉ MAC theo chuẩn IEEE, trong đó có 3-byte cho nhà sản xuất thiết bị và 3-byte cho thiết bị
 - **AM_ADDR (Active Member Address):** Một số 3-bit dùng để phân biệt giữa các active slave trong một Piconet. 000 là địa chỉ quảng bá.
 - **PM_ADDR (Parked Member Address):** Một số 8-bit dùng để phân biệt giữa các parked slave (inactive)
 - **AR_ADDR (Access Request Address):** Dùng trong các bản tin yêu cầu truy cập. AR_ADDR được gán cho các parked slave và không nhất thiết phải đảm bảo tính đơn nhất

- Có 04 trạng thái chính của một thiết bị Bluetooth trong mạng:
 - **Inquiring device (inquiry mode):** Thiết bị đang phát tín hiệu để tìm những thiết bị khác
 - **Inquiry scanning device (inquiry scan mode):** Thiết bị nhận tín hiệu inquiry của thiết bị inquiry device khác và phản hồi
 - **Paging device (page mode):** Thiết bị phát tín hiệu yêu cầu kết nối với thiết bị khác
 - **Page scanning device (page scan mode):** Thiết bị nhận yêu cầu kết nối từ thiết bị khác và phản hồi

- Quản trị Piconet
 - Gán/gỡ bỏ thiết bị Slave với/từ một Piconet
 - Hoán đổi vai trò Master-slave của thiết bị
 - Khởi tạo liên kết SCO và ACL
 - Đặt một kết nối trong chế độ năng lượng thấp
- Cấu hình liên kết
 - Điều khiển mức tiêu thụ năng lượng
 - Thỏa thuận về khuôn dạng gói tin
- Bảo mật
 - Xác thực thiết bị
 - Mã hóa dữ liệu

Host Controller Interface (HCI)

- Cung cấp giao diện cho phép các tầng bên trên điều khiển Baseband Controller và Link Manager, đồng thời cho phép truy cập đến trạng thái của phần cứng và điều khiển các thanh ghi
- HCI tồn tại trong ba phần: Host – Transport Layer – Host Controller. Host (máy tính, thiết bị di động, thiết bị ngoại vi) gửi lệnh HCI đến Host Controller (Bluetooth chipset) thông qua một số loại bus như UART, RS232. Host Controller có thể gửi phản hồi hoặc lệnh đến Host dưới dạng các event packet và data packet.

Các chế độ bảo mật

- **Security Mode 1:** Non-secure
- **Security Mode 2:** Service-level enforced security
- **Security Mode 3:** Link level security
- **Security Mode 4:** Service-level enforced security

Mode 4 Level	FIPS approved algorithms	MITM protection	User interaction during pairing	Encryption required
4	Yes	Yes	Acceptable	Yes
3	No	Yes	Acceptable	Yes
2	No	No	Minimal	Yes
1	No	No	Minimal	Yes
0	No	No	None	No

- **Encryption Mode 1:** No encryption
- **Encryption Mode 2:** Mã hóa lưu lượng bằng khóa mã trừ lưu lượng quảng bá
- **Encryption Mode 3:** Mã hóa tất cả lưu lượng. Sử dụng cùng cơ chế mã hóa tương tự như Mode 2.

Các mức tin cậy, dịch vụ và ủy quyền

- Các mức tin cậy
 - **Tin cậy:** Có quan hệ cố định với một thiết bị khác và có quyền truy cập đến tất cả dịch vụ
 - **Không tin cậy:** Giữa hai thiết bị không có quan hệ vì thế quyền truy cập đến một số dịch vụ bị giới hạn
- Các mức dịch vụ
 - **Dịch vụ mức 1:** Yêu cầu xác thực và ủy quyền
 - **Dịch vụ mức 2:** Chỉ yêu cầu xác thực
 - **Dịch vụ mức 3:** Mở cho tất cả thiết bị

Các thực thể bảo mật

- **PIN:** Một số 128 bit
- **BD_ADDR:** Địa chỉ thiết bị Bluetooth (Chuỗi 48 bit)
- **Link key:** Một số ngẫu nhiên 128 bit, sử dụng để xác thực thiết bị. Hai thiết bị ghép cặp chia sẻ cùng một link key
- **Encryption Key:** Khóa có độ dài thay đổi (8 – 128 bit), được khởi tạo lại cho mỗi lần trao đổi dựa trên link key
- **IN_RAND:** Số ngẫu nhiên 128 bit, được tạo bằng phần mềm của thiết bị và là thành phần không thể thiếu để tạo khóa

Cơ chế ghép cặp

- Cơ chế ghép cặp truyền thống (Legacy pairing)
- Secure Simple Pairing

Cơ chế ghép cặp truyền thống (Legacy pairing)

- Bao gồm 5 bước:
 - Bước 1: Tạo Initialization key (K_{init})
 - Bước 2: Xác thực thiết bị
 - Bước 3: Tạo Link key
 - Bước 4: Trao đổi Link key
 - Bước 5: Tạo Ciphering key

Legacy Pairing - Tạo K_{Init}

- K_{Init} là khóa tạm thời được tạo trong quá trình ghép cặp thiết bị. Mục đích của nó là bảo vệ link key và chỉ sử dụng trong trường hợp hai thiết bị chưa từng có giao tiếp trước đó
- $K_{\text{Init}} = E_{22}(\text{PIN}, \text{sizeof}(\text{PIN}), \text{IN_RAND}, \text{BD_ADDR})$
- K_{Init} tồn tại cho đến khi hai thiết bị đã thống nhất về link key

Legacy Pairing - Tạo Link key

- Link key: Unit key vs. Combination key

- Combination key: $K_{AB} = K_A \text{ XOR } K_B$

$$K_A = E_{21}(\text{LK_RAND}_A, \text{BD_ADDR}_A)$$

$$K_B = E_{21}(\text{LK_RAND}_B, \text{BD_ADDR}_B)$$

$$C_A = \text{LK_RAND}_A \text{ XOR } K_{\text{Init}}$$

$$C_B = \text{LK_RAND}_B \text{ XOR } K_{\text{Init}}$$

$$C_B \text{ XOR } K_{\text{Init}}$$

$$C_A \text{ XOR } K_{\text{Init}}$$

- Link key K có thể là K_{Init} hoặc K_{AB}

Legacy Pairing - Tạo Master key

- Master key là khóa tạm thời, dùng như Link key để bảo vệ dữ liệu trong trường hợp Master gửi bản tin quảng bá đến các Slave
- $K_{\text{Master}} = E_{22}(\text{LK_RAND}_1, \text{LK_RAND}_2, 16)$
- K_{Master} được gửi đến B nhưng ở dạng đã mã hóa thông qua $K_{\text{AB}} = K_{\text{Master}} \text{ XOR } K_{\text{Ovl}}$, trong đó K_{Ovl} là overlay key: $K_{\text{Ovl}} = E_{22}(K, \text{RAND}_3, 16)$

Secure Simple Pairing

- Secure Simple Pairing (SSP) đơn giản hóa quá trình ghép cặp với nhiều mô hình liên kết:
 - Numeric Comparison
 - Passkey Entry
 - Just Works
 - Out of Band (OOB)
- Mỗi thiết bị Bluetooth đều sở hữu một cặp khóa ECDH:
 - Bước 1: Trao đổi khóa công khai trước khi thực hiện ghép cặp
 - Bước 2: Xác thực giai đoạn 1 (phụ thuộc mô hình liên kết)
 - Bước 3: Xác thực giai đoạn 2
 - Bước 4: Tạo Link key
 - Bước 5: Tạo Cipherring key

Secure Simple Pairing – Numeric Comparison

- Bước 1: Trao đổi Input/Output capability (IOCAP)
- Bước 2: Trao đổi khóa công khai
 - Giả sử cặp khóa của A, B là $(SK_A, PK_A), (SK_B, PK_B)$
 - A và B trao đổi PK_A, PK_B
 - A và B tính toán giá trị K_{DH} theo tiêu chuẩn P192 hoặc P256
- Bước 3: Xác thực giai đoạn 1
 - A và B chọn hai số ngẫu nhiên N_A, N_B
 - B gửi A giá trị $C_B = f1(PK_B, PK_A, N_B, 0)$
 - A và B trao đổi giá trị N_A, N_B
 - A xác minh giá trị C_B
 - A và B tính toán $V_A = g(PK_A, PK_B, N_A, N_B)$ và $V_B = g(PK_A, PK_B, N_A, N_B)$
 - Người dùng so sánh và xác minh giá trị V_A, V_B

Secure Simple Pairing – Numeric Comparison

- Bước 4: Xác thực giai đoạn 2
 - A và B tính toán, trao đổi và xác thực giá trị $E_A = f3(K_{DH}, N_A, N_B, 0, IOCAP_A, A, B)$ và $E_B = f3(K_{DH}, N_B, N_A, 0, IOCAP_B, B, A)$
- Bước 5: Tạo Link key

Link key = $f2(K_{DH}, N_{Master}, N_{Slave}, \text{"btlk"}, BD_ADDR_{Master}, BD_ADDR_{Slave})$

Trong đó N_{Master}, N_{Slave} tương ứng với hai giá trị N_A, N_B

Cơ chế xác thực thiết bị

- Cơ chế xác thực truyền thống (Legacy Authentication)
- Secure Authentication

Legacy Authentication

- Claimant vs. Verifier
- Giả sử **A** là verifier và **B** là claimant. **A** gửi cho **B** một số ngẫu nhiên **AU RAND** có độ dài 128-bit. **B** phản hồi **A** bằng bản tin:

$$(SRES, ACO) = E_1(K, AU_RAND, BD_ADDR_B)$$

K: Link key

E_1 : Hàm dựa trên SAFER++

- **SRES**: Signed Response
- **A** xác thực dựa trên việc so sánh giá trị **AU RAND** gửi đi và giá trị **AU RAND** nhận được.
- **B** cũng thực hiện xác thực **A** với cơ chế tương tự được hỗ trợ bởi Link Manager

Legacy Authentication

- ACO (Authenticated Cipher Offset) là một số có độ dài 96-bit được tạo ra cùng thời điểm với SRES
- ACO được lưu lại nếu xác thực thành công. Trong trường hợp khác, người dùng phải đợi một khoảng thời gian để thực hiện lại quy trình xác thực
- ACO được sử dụng để tạo Ciphering key

Secure Authentication

- Master gửi cho Slave một chuỗi ngẫu nhiên 128-bit RAND_M
- Slave gửi cho Master một chuỗi ngẫu nhiên 128-bit RAND_S
- Master và Slave sử dụng hàm h4 và h5 (HMAC-SHA-256) để tính toán giá trị cần phản hồi dựa trên địa chỉ ADDR_M và ADDR_S. Lưu ý rằng chỉ 32-bit đầu tiên của mã băm được dùng cho mục đích xác thực. 96-bit còn lại tương ứng với giá trị ACO.
- Slave gửi 32-bit xác thực đã được ký đến Master
- Master gửi 32-bit xác thực đã được ký đến Slave
- Master và Slave so khớp mã hiện có và mã nhận được. Nếu trùng nhau, quá trình xác thực thành công. Ngược lại, quá trình xác thực thất bại

Tạo Cipherring key

- K_C được tạo ra từ Unit, Combination hoặc Master key với độ dài có thể ngắn hơn 128-bit
- $K_C = E_3(K, EN_RAND, COF)$
- Việc tính toán COF dựa trên BD_ADDR của thiết bị Master nếu Master key được sử dụng như Link key. Trong trường hợp khác, COF bằng giá trị ACO.
- EN_RAND do thiết bị Master khởi tạo trước khi thực thi chế độ mã hóa. Lưu ý rằng EN_RAND được truyền ở dạng bản rõ trong môi trường không dây

Payload Key

- Payload Key (K_p) là khóa dùng để mã hóa và giải mã các gói tin
- $K_p = E_0(K_C, \text{Clock}, \text{BD_ADDR}, \text{EN_RAND})$
- Clock là một số 26-bit tương ứng với thời gian trên đồng hồ của thiết bị

Các nguy cơ với Bluetooth

Nguy cơ	Chú thích	Phiên bản liên quan
Link key dựa trên Unit key	Thiết bị sử dụng cùng một Link key khi ghép cặp với tất cả thiết bị khác, tạo ra lỗ hổng bảo mật nghiêm trọng trong cơ chế quản lý khóa, và nguy cơ bị tấn công giả mạo	1.0, 1.1, 1.2
Security Mode 1	Khuyến nghị sử dụng Security Mode 2, 3	1.0, 1.1, 1.2
Mã PIN	Mã PIN được dùng để tạo Link key nên không đảm bảo nếu độ dài ngắn hoặc dễ đoán. Việc lạm dụng mã PIN tạo khó khăn cho người sử dụng và khả năng mở rộng của sản phẩm	1.0, 1.1, 1.2, 2.0
K_p bị lặp lại sau 23.3 giờ	Giá trị K_p phụ thuộc vào thời gian của đồng hồ thiết bị và có thể lặp lại sau 23.3 giờ	1.0, 1.1, 1.2, 2.0
Mô hình Just Works không cung cấp cơ chế ngăn chặn tấn công MITM	Kích hoạt sử dụng các mô hình khác ngoài Just Works	2.1, 3.0, 4.0, 4.1, 4.2

Các nguy cơ với Bluetooth

Nguy cơ	Chú thích	Phiên bản liên quan
Sử dụng cặp khóa ECDH tĩnh hoặc không đủ mạnh	Tất cả các thiết bị Bluetooth được khuyến nghị sử dụng cặp khóa ECDH mạnh. Mục đích là ngăn chặn nguy cơ tin tặc thực hiện các hành vi nghe lén, từ đó xác định Link key	2.1, 3.0, 4.0, 4.1, 4.2
Sử dụng Passkey tĩnh	Trong SSP, Passkey cung cấp khả năng phòng chống tấn công MITM. Thiết bị Bluetooth nên sử dụng Passkey ngẫu nhiên và thay đổi sau mỗi lần ghép cặp	2.1, 3.0, 4.0, 4.1, 4.2
Thiết bị thuộc Security Mode 4 phải thiết lập chế độ bảo mật thấp hơn khi ghép cặp với thiết bị không hỗ trợ Security Mode 4	NIST khuyến nghị chỉ nên ghép đôi với thiết bị có chế độ bảo mật tối thiểu là Security Mode 3	2.1, 3.0, 4.0, 4.1, 4.2
Không giới hạn số lần xác thực sai	Chuẩn Bluetooth đòi hỏi tăng thời gian chờ theo cấp số mũ giữa các lần xác thực đúng, nhưng không đưa ra thời gian chờ nếu xác thực thất bại	

Các nguy cơ với Bluetooth

Nguy cơ	Chú thích	Phiên bản liên quan
Khóa Master được chia sẻ với nhiều thiết bị trong một Piconet	Nguy cơ tấn công bị tấn công mạo danh khi khóa bí mật được chia sẻ cho nhiều thiết bị	1.0, 1.1, 1.2, 2.0, 2.1, 3.0
Thuật toán E_0 chưa thực sự phù hợp cho mã hóa dữ liệu	Lưu ý: BLE sử dụng AES-CCM	1.0, 1.1, 1.2, 2.0, 2.1, 3.0, 4.0
Quyền riêng tư bị ảnh hưởng nếu BD_ADDR được gán cho một người dùng cụ thể	Hoạt động của người dùng có thể bị theo dõi, giám sát thông qua địa chỉ BD_ADDR	1.0, 1.1, 1.2, 2.0, 2.1, 3.0
Cơ chế ghép cặp trong BLE thiếu biện pháp ngăn chặn nghe lén	Nếu thành công, tin tặc có thể lấy được khóa bí mật trong quá trình ghép đôi	4.0, 4.1

Các nguy cơ với Bluetooth

Nguy cơ	Chú thích	Phiên bản liên quan
Secure Mode 1 Level 1 trong BLE không yêu cầu mã hóa cũng như xác thực	NIST khuyến nghị sử dụng Security Mode 1 Level 4	4.0, 4.1, 4.2
Mức độ an toàn của trình sinh số giả ngẫu nhiên không được kiểm chứng	Trình sinh số giả ngẫu nhiên có thể tạo ra các số tĩnh hoặc có tính chu kỳ. Việc tích hợp thiết bị Bluetooth nên dựa trên các thuật toán PRNG khuyến nghị bởi NIST	
Link key được lưu trữ tại những vị trí không an toàn	Tin tặc có thể đánh cắp hoặc can thiệp sửa đổi Link key	
Kích thước của K_C có thể thỏa hiệp	Bluetooth phiên bản dưới 3.0 cho phép thiết bị thỏa hiệp khóa với độ dài nhỏ nhất là 8-bit. NIST khuyến nghị sử dụng thuật toán AES-CCM với khóa 128-bit	1.0, 1.1, 1.2, 2.0, 2.1, 3.0

Các nguy cơ với Bluetooth

Nguy cơ	Chú thích	Phiên bản liên quan
Không tồn tại cơ chế xác thực người dùng	Phần mô tả chỉ tập trung xác thực thiết bị, trong khi thiếu vắng cơ chế bảo mật ở lớp ứng dụng, trong đó có bài toán xác thực người dùng	
Không thực thi cơ chế mã hóa E2EE	E2EE nằm trên chồng giao thức Bluetooth và có thể được cung cấp thông qua việc sử dụng các biện pháp bổ sung	
Các dịch vụ bảo mật tương đối hạn chế	Kiểm thử, chống chối bỏ là những dịch vụ không nằm trong tiêu chuẩn Bluetooth	
Với hai thiết bị đã ghép cặp, một số trường hợp thuộc Security Mode 3, 4 không yêu cầu xác thực hai chiều	Thiết bị A đã ghép cặp với B. Nếu A là thiết bị khởi phát hành động xác thực và các thiết lập mã hóa của A được B chấp thuận, B không nhất thiết phải xác thực A	1.0, 1.1, 1.2, 2.0, 2.1, 3.0

Các mối đe dọa với Bluetooth

- Bluesnarfing
- Bluejacking
- Bluebugging
- Car Whisperer
- Denial of Service
- Fuzzing Attacks
- Pairing Eavesdropping
- Secure Simple Pairing Attacks

- Tìm hiểu về các điểm yếu trong cơ chế mã hóa, các mô hình liên kết SSP cũng như cấu hình của thiết bị Bluetooth (Chương 3, K. Haataja, K. Hypponen, S. Pasanen, P. Toivanen, “Bluetooth Security Attacks: Comparative Analysis, Attacks, and Countermeasures”, Springer, ISBN 978-3-624-40645-4, 2013)
- Tìm hiểu về chuẩn NIST SP 800-121 Rev. 2 và danh sách các khuyến nghị để tăng cường bảo mật cho mạng Piconet.



TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

6LoWPAN

IPv6 over Low-Power Wireless PAN

ONE LOVE. ONE FUTURE.

Tổng quan về 6LoWPAN

- 6LoWPAN là mạng công suất thấp. Mỗi nút trong 6LoWPAN được đánh địa chỉ IPv6 và có thể kết nối với những mạng khác thông qua thiết bị định tuyến biên
- 6LoWPAN sử dụng sồ đồ mạng hình sao, lưới hoặc kết hợp cả hai, phụ thuộc vào sự di biến động của thiết bị trong môi trường vận thành
- Tầng PHY và MAC của 6LoWPAN tương thích với chuẩn IEEE 802.15.4-2003

Tổng quan về 6LoWPAN



	802.15.4	802.15.1	802.15.3	802.11	802.3
Class	WPAN	WPAN	WPAN	WLAN	LAN
Lifetime (days)	100-1000+	1-7	Powered	0.1-5	Powered
Net Size	65535	7	243	30	1024
BW (kbps)	20-250	720	11,000+	11,000+	100,000+
Range (m)	1-75+	1-10+	10	1-100	185 (wired)
Goals	Low power, Large scale, Low cost	Cable replacement	Cable replacement	Throughput	Throughput



Chồng giao thức 6LoWPAN

Chồng giao thức TCP/IP

HTTP		RTP	
TCP	UDP	ICMP	
IP			
Ethernet MAC			
Ethernet PHY			

Application

Transport

Network

Data Link

Physical

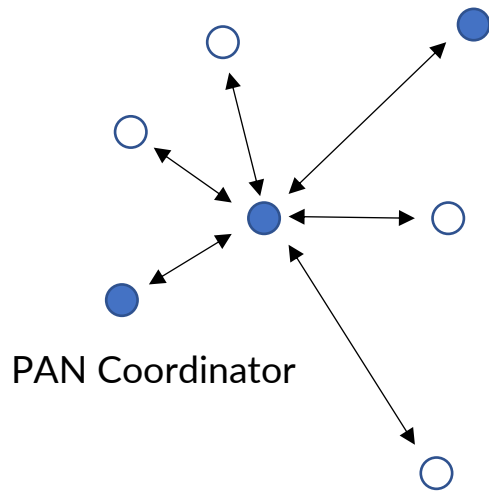
Chồng giao thức 6LoWPAN

Application	
UDP	ICMP
IPv6	
IEEE 802.15.4 MAC	
IEEE 802.15.4 PHY	

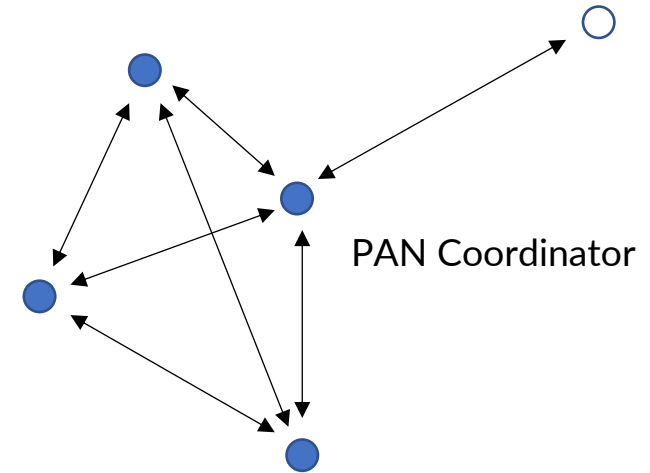
Thiết bị IPv6 biên hỗ trợ 6LoWPAN

IPv6	
Ethernet MAC	LoWPAN adaptation
	IEEE 805.15.4 MAC
Ethernet PHY	IEEE 805.15.4 PHY

Kiến trúc LoWPAN



Sơ đồ hình sao



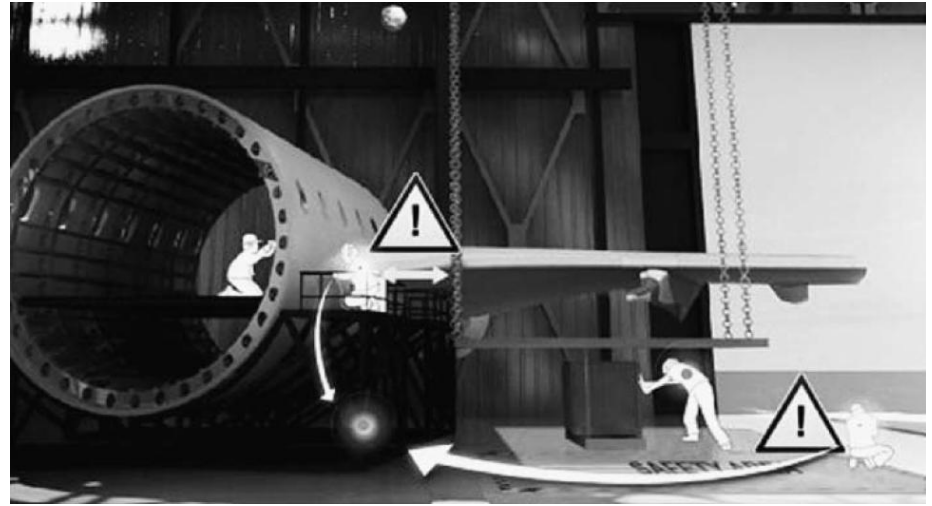
Sơ đồ theo mô hình P2P

Octet: 2	1	0/2	0/2/8	0/2	0/2/8	Variable	2
Frame Control	Sequence number	Destination PAN identifier	Destination address	Source PAN identifier	Source address	Frame payload	FCS
		Addressing fields					
MHR						MAC payload	MFR

Khung dữ liệu MAC

Ứng dụng của 6LoWPAN

- Thiết bị chăm sóc và giám sát sức khỏe
- Thiết bị giám sát môi trường
- Thiết bị giám sát đảm bảo an ninh, trật tự xã hội
- Nhà thông minh, thành phố thông minh



Đặc tính kỹ thuật

- Kích thước khung dữ liệu: 127 bytes
- Địa chỉ MAC: 16-bit hoặc 64-bit
- Tốc độ truyền dữ liệu: 250/40/20 kbps
- Môi trường mạng: Không ổn định
- Hỗ trợ mã hóa AES với một số chế độ cơ bản
- Phạm vi hoạt động của mạng: 30 m
- Sơ đồ hình trạng mạng: Hình sao và/hoặc hình lưới
- Đặc điểm thiết bị: Tài nguyên hạn chế, tiêu thụ ít năng lượng

IPv6 over IEEE 802.15.4

- Kích thước gói tin IPv6: 1280 bytes
- Kích thước khung dữ liệu 802.15.4: 127 bytes
 - Phần tiêu đề khung dữ liệu (Max): 25 bytes
 - Phần tiêu đề cho nhu cầu bảo mật tại lớp liên kết (Max): 21 bytes
 - Phần tiêu đề IPv6: 40 bytes
 - Phần tiêu đề cho giao thức tầng giao vận: 8 bytes
 - Phần dữ liệu của ứng dụng: **33** bytes

Cách thức nén phần tiêu đề

Ver	Traffic Class	Flow label	Payload length	Next header	Hop limit	Source address	Destination address
-----	---------------	------------	----------------	-------------	-----------	----------------	---------------------

Phần tiêu đề IPv6

Dispatch	Compressed header
----------	-------------------

2 bytes

Dispatch	Compressed header	CID	Hop limit	Destination address
----------	-------------------	-----	-----------	---------------------

12 bytes

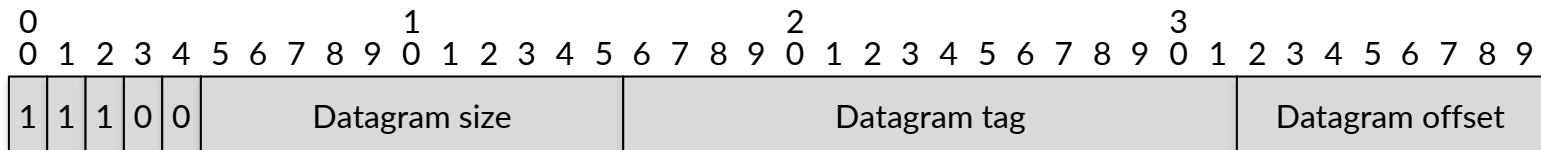
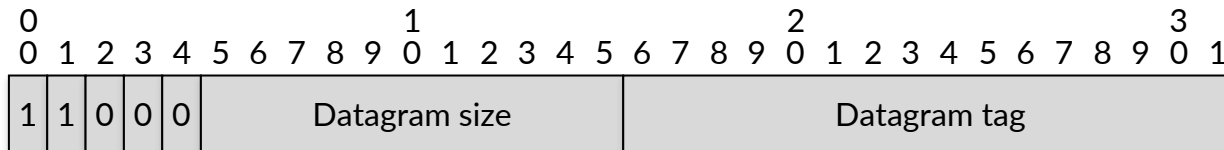
Dispatch	Compressed header	CID	Hop limit	Source address	Destination address
----------	-------------------	-----	-----------	----------------	---------------------

20 bytes

Giá trị Dispatch

Pattern		Header Type	
00	xxxxxx	NALP	Not a LoWPAN frame
01	000001	IPv6	Uncompressed IPv6 Addressses
01	000010	LOWPAN_HC1	LOWPAN_HC1 compressed IPv6
01	010000	LOWPAN_BC0	LOWPAN_BC0 broadcast
01	111111	ESC	Additional Dispatch byte follows
10	xxxxxx	MESH	Mesh Header
11	000xxx	FRAG1	Fragmentation Header (First)
11	100xxx	FRAGN	Fragmentation Header (Subsequent)

Phân mảnh dữ liệu



Datagram size: Kích thước của toàn bộ gói tin trước khi phân mảnh

Datagram tag: Giá trị định danh của mảnh dữ liệu

Datagram offset: Khoảng cách tính theo đơn vị byte

Thiết lập và vận hành mạng 6LoWPAN

- Giao tiếp giữa các nút mạng: Đòi hỏi tương thích trong cấu hình tại tầng vật lý và liên kết dữ liệu (kênh truyền, phương pháp điều chế, tốc độ, cách thức đánh địa chỉ, bảo mật)
- 6LoWPAN Neighbor Discovery (RFC6775) cung cấp cơ chế (1) khai phá và duy trì kết nối với các nút mạng trong cùng liên kết, (2) tìm kiếm thiết bị định tuyến, (3) phát hiện lặp địa chỉ, và (4) giảm thiểu số lượng gói tin truyền quảng bá.

Bảo mật tại tầng liên kết dữ liệu

- Phương thức mã hóa: AES-CCM (Counter with CBC-MAC)
- Mức độ bảo mật của AES-CCM phụ thuộc vào giá trị khóa (k) và số nguyên nonce (N). N có không gian tương đương 13 byte, đảm bảo mã hóa được 2^{32} bản tin gửi từ cùng một địa chỉ nguồn (tương đương với thời gian 7 tuần).
- Bảo mật tại tầng liên kết dữ liệu không đảm bảo tính mật khi dữ liệu trung chuyển qua các nút mạng trung gian.

- Phương thức bảo mật: IPSec (RFC4301)
- Định nghĩa hai dạng gói tin:
 - Authentication Header (AH) (RFC4302)
 - Encapsulating Security Payload (ESP) (RFC4303)
- ESP sử dụng AES/CCM (RFC4309), phù hợp với mạng 6LoWPAN và có khả năng khai thác được phần cứng mã hóa/giải mã của thiết bị IEEE 802.15.4

- **Khóa dài hạn** (Long-term key): Được sử dụng để mã hóa khóa ngắn hạn thay vì mã hóa trực tiếp lưu lượng mạng.
- **Khóa ngắn hạn** (Short-term key): Được sinh ra từ khóa dài hạn và giá trị nonce để mã hóa trực tiếp lưu lượng mạng.
- **Khóa theo cặp** (Pairwise key): Mã hóa và xác thực dữ liệu trao đổi giữa hai thực thể (thiết bị)
- **Khóa nhóm** (Group key): Sử dụng trong truyền quảng bá



TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

Routing Protocol for Low Power and Lossy Networks

ONE LOVE. ONE FUTURE.

Tổng quan về mạng tiêu thụ năng lượng thấp

- Nút mạng bị hạn chế là một nút mạng bị giới hạn về bộ nhớ, tài nguyên tính toán do những vấn đề liên quan đến giá thành, kích thước cũng như năng lượng tiêu thụ. Nó có ngưỡng chặn trên về không gian lưu trữ, thời gian xử lý các tác vụ, băng thông mạng, và có thể thiếu vắng một số dịch vụ như truyền quảng bá (RFC 7228)
- Mạng bị hạn chế là mạng với những đặc tính:
 - Thông lượng thấp
 - Tỷ lệ mất mát gói tin lớn
 - Những đặc tính của liên kết bất đối xứng
 - Vấn đề trong xử lý gói tin có kích thước lớn
 - Trạng thái hoạt động không liên tục của các nút mạng

Tổng quan về mạng tiêu thụ năng lượng thấp

- Mạng LLN là một mạng bị giới hạn gồm tập hợp các thiết bị có hạn chế về bộ nhớ, tài nguyên tính toán
- Ứng dụng của mạng LLN
 - Hệ thống giám sát trong công nghiệp
 - Hệ thống tự động hóa tòa nhà (HVAC)
 - Hệ thống điều khiển ánh sáng
 - Kiểm soát vào ra
 - Chăm sóc sức khỏe
 - Hệ thống giám sát môi trường
 - Hệ thống quản lý năng lượng tiêu thụ
 - Hệ thống theo dõi, kiểm soát tài sản

Tổng quan về RPL

- Routing Protocol for Low Power and Lossy Networks (RPL) là giao thức định tuyến cho mạng tiêu thụ năng lượng thấp nói chung và mạng cảm biến nói riêng. Dự thảo của RPL được xuất bản lần đầu vào tháng 8/2009. Hiện giao thức vẫn đang được nghiên cứu và hoàn thiện
- RPL là giao thức dựa trên vectơ khoảng cách (Distance vector protocol) và định tuyến bởi thiết bị nguồn (Source routing protocol)
- RPL có hai chế độ hoạt động là storing và non-storing. RPL sử dụng các DAG trong mạng để định tuyến

Một số định nghĩa

- Directed Acyclic Graph (DAG)
- DAG root
- Destination Oriented DAG
- Hạng (Rank)
- Hàm mục tiêu (Objective Function – OF)
- RPLInstanceID
- RPL Instance
- Nút DODAG cha (DODAG parent)
- Phiên bản DODAG (DODAG version)
- DODAG repair

Các loại bản tin trong RPL

- **DIO - DODAG Information Object** mang thông tin cho phép các nút có thể phát hiện một RPL Instance, các tham số cấu hình, lựa chọn nút cha và duy trì DODAG
- **DIS - DODAG Information Solicitation** sử dụng để một nút quảng bá sự xuất hiện của nó trong DODAG, tham dò các nút lân cận và yêu cầu nút khác phản hồi bằng bản tin DIO
- **DAO - Destination Advertisement Object** dùng để gửi thông tin đường đi tới đích cho các nút nằm bên trên trong DODAG
- **DAO-ACK** gửi bởi nút nhận để phản hồi cho bản tin DAO

Quá trình khởi tạo mạng

- Mỗi RPL Instance gồm một hoặc một vài DAG root. Các thông số định tuyến được thiết lập phù hợp mục đích triển khai. DAG root định kỳ gửi bản tin DIO quảng bá đến các nút xung quanh để xây dựng DAG
- Các nút thiết lập DODAG root là nút cha, và xác định rank của nó trên cơ sở hàm mục tiêu định nghĩa trong bản tin DIO. Nút tiếp tục chuyển tiếp bản tin DIO đến các nút lân cận
- Nút chọn nút cha phù hợp để đóng vai trò là trung gian chuyển tiếp các gói tin của nút tới DODAG root

Duy trì và phát triển mạng

- Bản tin DIO được gửi định kỳ để cập nhật thông tin. Tần suất của nó có thể phụ thuộc vào trạng thái của mạng
- Một nút khi muốn tham gia DODAG phải gửi bản tin DIS theo hình thức quảng bá để nhận DIO từ nút lân cận
- RPL tích hợp cơ chế để xử lý vòng lặp, phát hiện sự thiếu nhất quán và sửa chữa DODAG

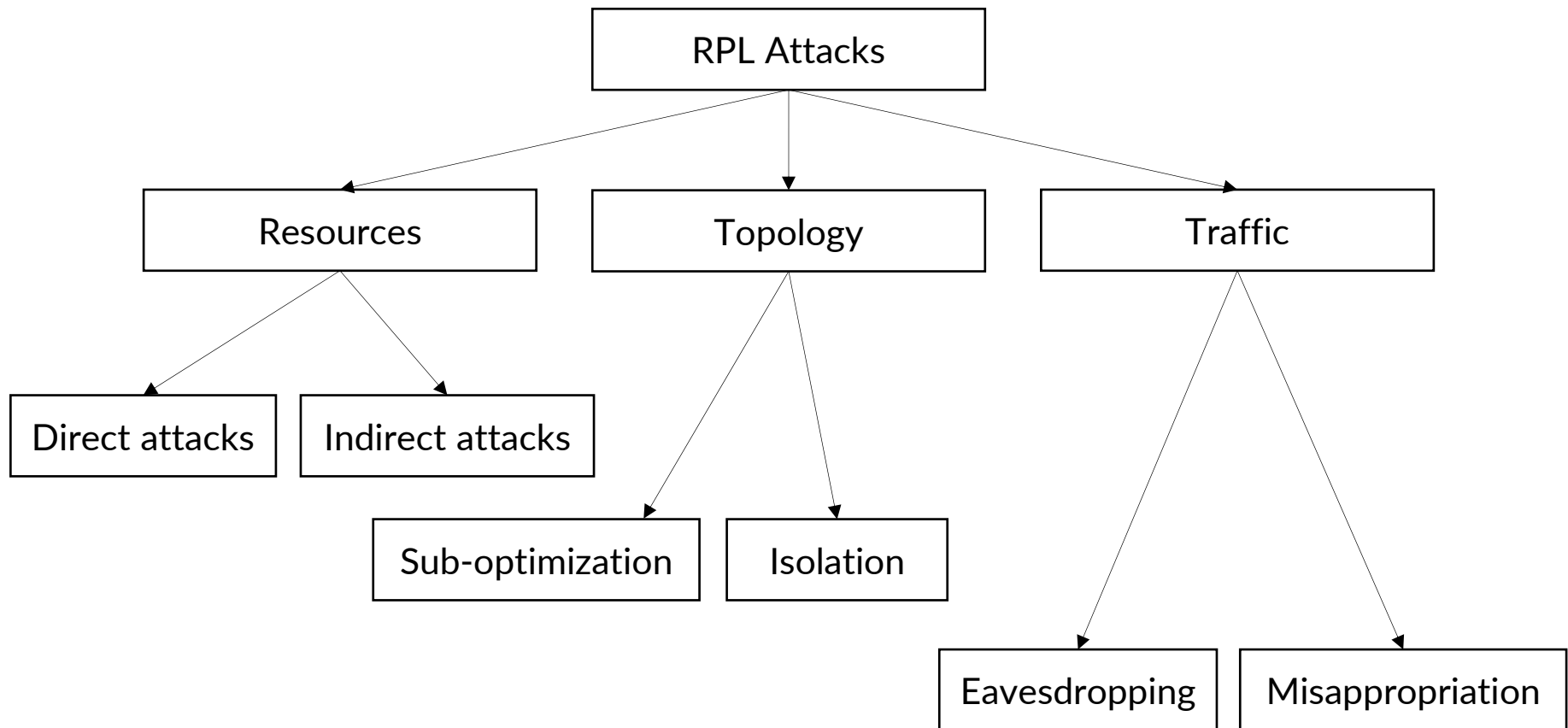
- RPL hỗ trợ ba chế độ bảo mật:
 - Unsecured
 - Preinstalled
 - Authenticated
- RPL giả thiết một nút muốn tham gia mạng phải được cấu hình sẵn một khóa bí mật chia sẻ trước để kết nối với các nút lân cận và DODAG root
- RPL gửi các bản tin Consistency Check (CC) để đồng bộ giá trị của bộ đếm bảo mật, phục vụ cho mục đích ngăn chặn tấn công phát lại

- RPL sử dụng bộ đếm với hai tùy chọn:
 - Một số tự nhiên tăng dần sau mỗi lần truyền tin
 - Một nhãn thời gian
- RPL sử dụng các trường T, Security Algorithm, Key Identifier Mode (KIM), và Security Level (LVL) để mô tả mức độ bảo mật cũng như các cấu hình cần thiết để bảo vệ bản tin RPL. Giá trị của các trường phụ thuộc vào chính sách bảo mật của từng nút

Phân tích các mối đe dọa với RPL (RFC 7416)

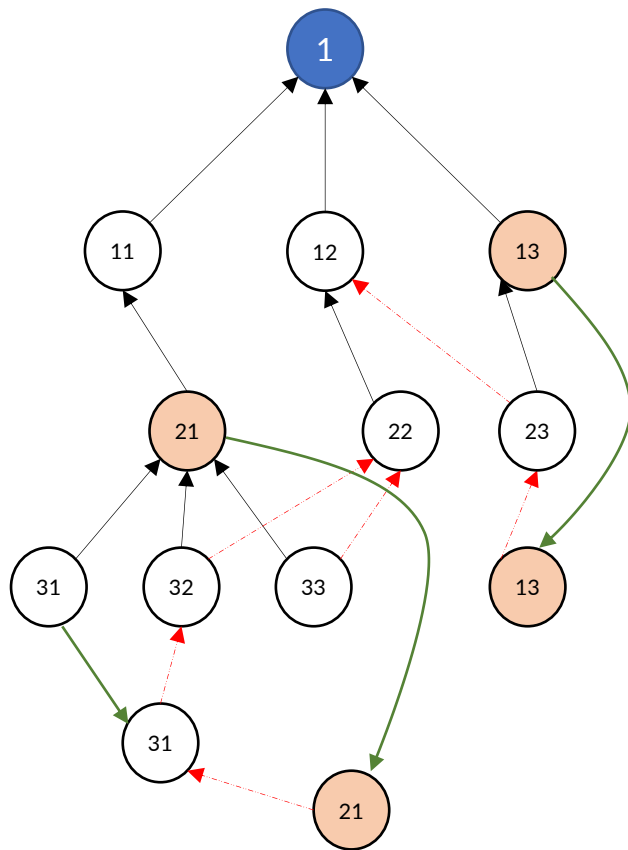
- Nguồn đe dọa (RFC 4593)
- Nguy cơ do lỗi xác thực nút mạng
- Nguy cơ do thất bại trong việc giữ mật thông tin định tuyến
- Nguy cơ tấn công tính toàn vẹn
- Nguy cơ tấn công tính sẵn sàng của hệ thống

Phân loại các dạng tấn công mạng RPL

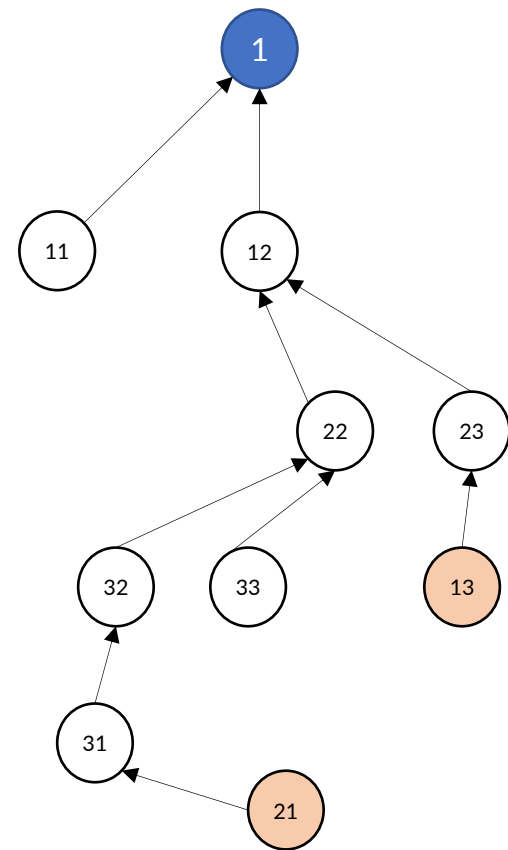


- Tấn công trực tiếp
 - Tấn công ngập lụt hệ thống
 - Tấn công dẫn đến tràn bảng định tuyến
- Tấn công gián tiếp
 - Tấn công tăng hạng
 - Tấn công vào tính không nhất quán của DAG
 - Tấn công thay đổi phiên bản

Minh họa tấn công tăng hạng



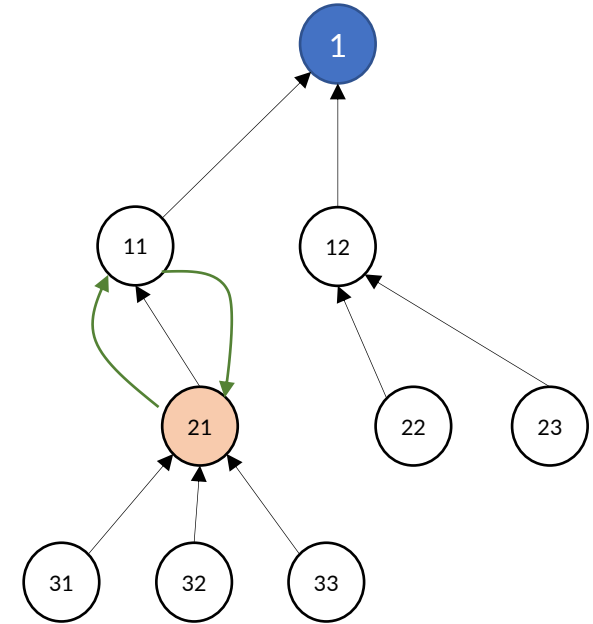
Trạng thái khởi tạo



Trạng thái cuối cùng

Tấn công hình trạng mạng

- Tấn công khiến mạng không đạt được trạng thái hội tụ tối ưu
 - Tấn công thay đổi thông tin định tuyến
 - Tấn công Sinkhole
 - Tấn công Wormhole
 - Tấn công phát lại thông tin định tuyến
 - Tấn công chọn nút cha tệ nhất
- Tấn công cô lập
 - Tấn công Blackhole
 - Tấn công vào tính không nhất quán của bản tin DAO



Tấn công lưu lượng mạng

- Tấn công nghe lén
 - Tấn công chặn bắt gói tin
 - Tấn công phân tích lưu lượng mạng
- Tấn công giả mạo
 - Tấn công giảm hạng
 - Tấn công giả mạo danh tính

Phân tích ảnh hưởng của các hình thức tấn công

Dạng tấn công	PDR (%)	E2ED (ms)	PC (mW)
Không tấn công	100,0	28,5	0,680
Tấn công ngập lụt hệ thống	99,2	28,7	0,814
Tấn công tăng hạng	67,2	∞	0,690
Tấn công vào tính không nhất quán của DAG	94,7	30,7	0,820
Tấn công thay đổi phiên bản	24,0	∞	0,782
Tấn công Sinkhole	98,4	36,1	0,689
Tấn công Blackhole	56,8	∞	0,677

Câu hỏi thảo luận

- Liệt kê các giải pháp có thể áp dụng để giảm thiểu nguy cơ lộ thông tin định tuyến.
- Liệt kê các giải pháp để ngăn chặn một số hình thức tấn công gồm (1) Tấn công phân tích dữ liệu, (2) Tấn công giả mạo danh tính, (3) Tấn công Selective Forwarding, (4) Tấn công Sinkhole, (5) Tấn công Blackhole, và (6) Tấn công Wornhole. Nêu những khó khăn trong quá trình triển khai giải pháp trên.
- Trình bày chi tiết nguyên tắc hoạt động của VeRA (A. Dvir, T. Holczer, L. Buttyan, “VeRA – Version Number and Rank Authentication in RPL”, 2011 IEEE Eighth International Conference on Mobile Ad-Hoc and Sensor Systems).